INTERNATIONAL CYBERSECURITY AND DIGITAL FORENSICS ACADEMY (ICDFA)

Governance, Compliance, and Risk (GCR)
Course 1: GRC101 - Introduction to Governance, Risk, and Compliance

Week 1 Scenario-Based Assignment:

GRC Frameworks and Principles

Title: Designing a GRC Framework for TechStart Innovations

Student Name: Najma Abdi Omar

Reg. No: **2025/GRC/10331**

Date: 24/07/2025

Overview

In this assignment, you will simulate the role of a GRC analyst for a fast-growing financial technology (fintech) company. You are expected to use your knowledge from **Week 1** to assess a real-world business scenario, identify security and compliance risks, and suggest solutions using Governance, Risk, and Compliance (GRC) best practices.

This assignment is designed to help you apply theoretical concepts to real-world use cases, preparing you for industry expectations. **Assignment Duration**

Time Allotted: 90 minutes
Work Mode: Individual or in pairs (maximum of 2 students)
Submission Format: Typed PDF

Scenario: TechStart Innovations

TechStart Innovations is a fintech startup with 50 employees. The company recently raised a Series A investment and is preparing for further funding. The company's core operations involve handling sensitive data such as:

- **Banking details** of users (must comply with PCI-DSS),
- **Personal data** of customers from the European Union (must comply with GDPR),
- **Internal source code and algorithms** (considered intellectual property and business secrets).

Technology Stack in Use:

- AWS Cloud for hosting

- GitHub for software development
- SaaS tools such as Slack and Salesforce

Current Challenges:

- TechStart has no formal GRC program.
- They are preparing for ISO 27001 certification.
- A recent phishing attempt nearly succeeded.
- Their audit highlighted weak access controls and lack of documentation.

Your role is to help TechStart build a strong foundation for their GRC framework using Week 1 concepts.

Assignment Tasks

Task 1: Establish the Business and Risk Context

Purpose: Understand how business goals influence compliance and risk decisions. Every GRC program begins with understanding what the business is trying to achieve and what assets are critical to its operations.

1.1 Business Objectives and Compliance Impact TechStart's three main goals are:

Business Goal	**What It Means**	**Related Compliance Requirement**
Expand into the German market	Must comply with European privacy laws	GDPR
Raise $10M Series B investment	Requires secure systems and investor confidence	SOC 2
Reduce security incidents by 60%	Needs better threat detection and response	ISO 27001

Your Task:

For each of the above goals, explain in 2–3 sentences how that goal drives the need for proper governance, risk management, and compliance. Refer to your lecture notes and frameworks discussed in Week 1.

Answer:

Goal 1: Expand into the German Market:

This goal drives the need for proper GRC implementation because expanding into the European Market requires more secure systems, policies and controls, without this it introduces significant legal and operational risks. A strong GRC framework ensures we have the right governance (assists in executive support), risk controls and compliance process to meet the regulatory requirements.

Goal 2: Raise $10M series B investment

To bring in investor, there is need to have an effective GRC program, this builds stakeholder confidence by strengthening credibility during due diligence, good framework demonstrates that a company is well-managed, compliant with regulations and is prepared to scale responsibly.

Goal 3: Reduce Security Incidents by 60%:

Reducing security incidents requires a structured approach towards risk. Benefits of effective GRC include Risk mitigation, by regularly identifying and addressing risks before they are actualized, enforcing security policies and monitoring controls, we contribute to reducing incidents and support long-term operational resilience and compliance.

1.2 Create an Asset Inventory Table

Purpose: Before implementing controls, the company must know what data and systems are critical to its operations. This is called **Asset Inventory**.

Fill out a table like the one below. You must list at least **three (3)** assets and classify their importance.

Asset Category	**Specific Asset**	**Owner**	**Related Compliance Rule**	**Importance Level**
Data	EU Customer Database	CTO	GDPR Article 30	High
Process	Payment Processing Flow	CFO	PCI-DSS Requirement 3	Critical
Technology	AWS Production Servers	DevOps	ISO 27001 Clause A.14	High

Answer:

Asset Category	**Specific Asset**	**Owner**	**Related Compliance Rule**	**Importance Level**
End Point Device	Employee Laptops	ICT Head	ISO 27001, Device Policy	Medium
CRM System	Salesforce CRM	Marketing Manager	GDPR	Medium
Development Tools	GitHub(Code Repository)	Engineering Lead	SOC2, Internal security Policy	High

1.3 Stakeholder Alignment Roleplay

Purpose: Many GRC initiatives fail because internal stakeholders (e.g., CFO, CTO) do not see the value. You must be able to explain why each GRC activity is important to the business.

Your Task:
Write a short paragraph or dialogue where you (as a GRC lead) try to convince the CFO why completing the asset inventory is necessary. Mention benefits such as investor confidence, regulatory compliance, audit readiness, and risk visibility.

Answer:

Dialogue:

CFO: I need to understand why we need to invest in this exercise, everything is working well, we have just paid for the BCM you requested last month, the cost is now too much.

GRC Lead(Me): Thank you madam for your continued support in our efforts to implement a secure environment. Risk assessment starts with knowing what assets exists, their importance and who owns them, it facilitates better decisions and makes it easier to plan our resources efficiently into prioritizing what is critical and it also assist in a faster response in case of an incident, knowing your landscape speeds up investigations and containment, this also supports our current PCI-DSS compliance exercise that we must complete before we are given the green-light for card acquiring project.

CFO: You are making sense, but what does this mean for our organization.

Me: To simply explain, you cannot protect what you don't know, knowing what systems, data, and tools the company uses and actually documenting, is like knowing everything in your house before you lock the door, it helps us track what we own and use so that we can protect customer information, follow the law and fix problems quickly. Without proper assets inventory we are guessing what needs to be secured.

CFO: Thank you, approved.

End.

(ps. If only it was this easy!)

Task 2: Perform Inherent Risk Assessment

Purpose: Use the **FAIR methodology** to calculate the level of risk TechStart is facing based on current gaps.

Scenario:

- A former employee still has access to GitHub. (Security Gap)
- There is no Single Sign-On (SSO) enforcement. (Weak Controls)
- If the source code is stolen, it could cause $2 million in damage.

Your Task:
Calculate the **Inherent Risk** using the formula from your Week 1 notes:

Inherent Risk = Threat Likelihood × Impact

- Threat Likelihood = 25% (0.25) • Impact = $2,000,000

Show your calculation and final value.

Answer:

Given Threat Likelihood: 25%(0.25), Impact: $2,000,000

Inherent calculation:

Inherent Risk= Threat Likelihood X Impact= 0.25 x 2,000,000=**$500,000**

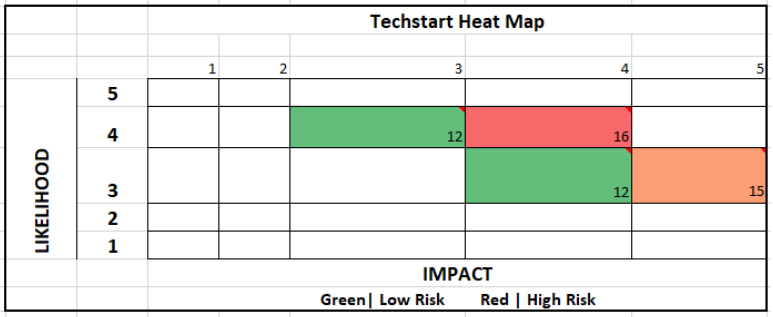
The inherent risk the TechStart is facing based on the security gap and weak controls is **$500,000**

Bonus (Optional): Create a Risk Heatmap

List five potential risks TechStart might face (e.g., phishing, insider threats, data breaches, unpatched systems) and plot them on a **simple risk heatmap** based on likelihood and impact. You can draw this manually or use Excel.

Answer Bonus*Excel Screenshot:

Risk	Likelihood (1-5)	Impact (1-5)	Score
Phishing Attacks	4	4	16
Insider Threat	3	5	15
Data Breaches	3	5	15
Unpatched Systems	4	3	12
Third Party Vendor Vulnarabilities	3	4	12



Task 3: Map Controls to ISO 27001

Purpose: Fix the identified problems using ISO 27001 controls. This task helps you apply the knowledge of **control mapping** and **gap analysis** discussed in Week 1.

Your Task:
Match each gap with the appropriate ISO 27001 control and the relevant feature in a GRC tool (e.g., Sprinto). Then, pick one issue and write how you would close the gap.

Problem Identified	**ISO 27001 Control**	**Sprinto Feature**
No employee training	A.7.2.2	Auto-assigned training modules
Shared admin passwords	A.9.2.3	Role-based access control
Servers not updated	A.12.6.1	Real-time monitoring alerts

Select one of the above issues and explain:

Answer:

Employee Training:

- Who is responsible: Leadership especially CISO and HR, however we have key stakeholder outlined in the table below:

Role	Shared Responsibilities
CISO or Head of Information Security	Owns the overall security strategy and is responsible for implementing awareness and training programs, this role is accountable for meeting compliance standards like ISO 27001 A.7.2.2
Human Resources	Coordinate onboarding and ongoing training programs
IT/Security Team	Provide technical content, run phishing simulation campaigns
Compliance officer	Ensures training aligns with regulatory and audit requirements
Department Heads and Line management	Ensure participation and understanding

- What steps need to be taken

The steps needed to be taken are informed by roadmaps: we need to assign ownership and state roles and responsibilities as shown in the table above, we then define the training requirements or scope based on regulatory obligation, choose the training method (interactive games, in-house presentation etc.), Customize contents based on staff roles, launch the training and track completion status, evaluate and improve and finally document the process.

- What tools can be used to fix the gap:

  The tools selected is structured to the budget and GRC maturity, we can use LMS (Learning Management System) or Security awareness games/simulations. The current top options Curricula, Microsoft Defender for office 365, etc. to select the most suitable tools we will require to go through Demos, POC/V and eventually selected the one most suited and adoptable to our environment.

Task 4: Present Your GRC Strategy

Purpose: Present your work as if you are briefing company leadership. This task helps you practice your communication skills and align GRC activities with business needs.

Create a 3-slide presentation (maximum):

- **Slide 1:** Why GRC Matters
  Link GRC efforts to TechStart's business goals, such as expansion, investment readiness, and risk reduction.
- **Slide 2:** Tool Recommendation
  Compare **Sprinto** vs **Secureframe** based on their suitability for a fintech startup. Use features, automation, cost, and ease of implementation as criteria.
- **Slide 3:** Overcoming Resistance
  Propose strategies for dealing with resistance to change (e.g., training, showing ROI, using quick wins).

You can use PowerPoint, Google Slides, or create this in your report as clearly separated sections or upload the ppt to the drive and attached the link to it, ensure to make it accessible to anyone with the link

Answer: Link:

https://docs.google.com/presentation/d/1xIUyJjvxy04qpfyNfZ0wzijTaAwCbsaU/edit?usp=drive_link&ouid=117914114061104068400&rtpof=true&sd=true

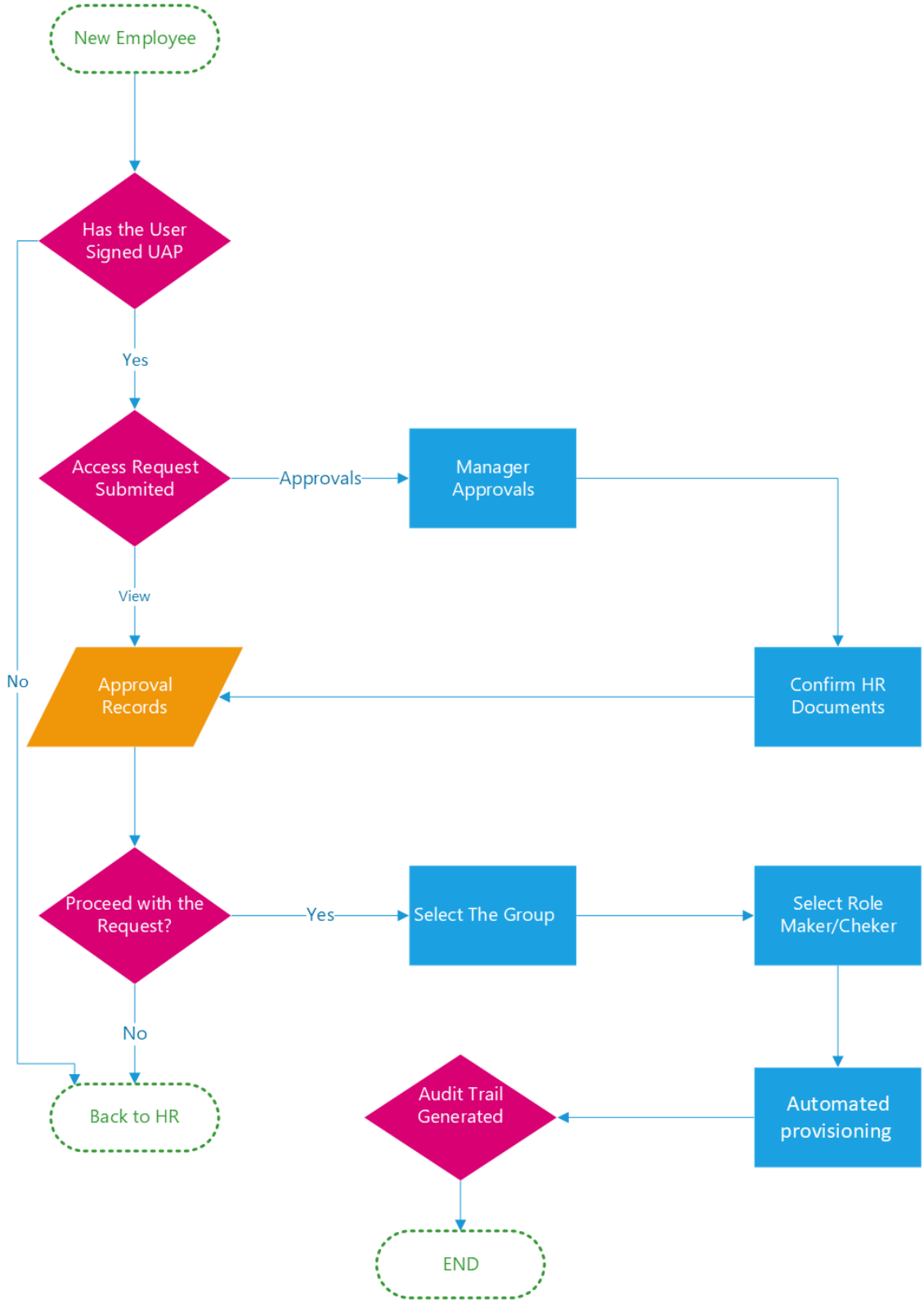
Optional Bonus Tasks (Extra Credit)

If you complete the main tasks early or wish to earn extra marks, you can complete one or more of the following:

1. **Evidence Collection Simulation:**
   Identify what logs or reports you would collect from AWS to demonstrate GDPR Article 30 compliance.
2. **Workflow Diagram:**
   Create a simple workflow showing:
   New employee → Access request → Approval → Automated provisioning → Audit trail generated

   Answer:

Workflow Diagram: Employee Access



3. **Budget Estimation:**
   Estimate how much GRC implementation might cost using the $20,000–$80,000 range. Justify your answer by considering:

   - Number of employees
   - Number of frameworks
   - Level of automation and tooling

Grading Rubric (Total: 20 Marks)

Section	Max Marks	What Will Be Assessed
Business Context & Inventory	4 marks	Relevance, clarity, and connection to compliance goals
Risk Calculation	4 marks	Correct use of FAIR model and logic
Control Mapping	4 marks	Accurate ISO 27001 linkage and realistic control plan
GRC Presentation	4 marks	Clear communication, creativity, and practical strategy
Bonus Tasks (Optional)	4 marks	Shows deeper understanding and real-world application

Final Notes

- All required knowledge comes from **Week 1 materials**: no outside research is required.
- Be clear, concise, and explain your reasoning.
- Use diagrams, charts, or screenshots if it helps make your ideas clearer.
- Practical thinking and alignment with business needs are more important than perfection.